Synthetic example. *Fictional organization and self-reported answers generated to demonstrate VERITRAIL outputs. Not evidence about any real organization.*

AI Governance Maturity Report — ExampleSoft (synthetic)

Assessment: AI Governance Maturity Self-Assessment (template VERITRAIL-SA-MATURITY v1.0.0)
Generated: 2026-10-21
Evidence status: User-asserted — all answers are self-reported; no evidence has been reviewed.

This self-assessment produces an indicative, self-reported view of AI governance maturity. All results are User-asserted: no evidence has been reviewed. Framework readiness indicators are not a determination of conformity with ISO/IEC 42001, compliance with the EU AI Act, or alignment with NIST AI RMF. VERITRAIL does not certify compliance and this report is not legal advice.

1. Overall maturity

Overall score	Maturity level	Interpretation
69.3 / 100	**Defined**	Core governance is established; expand coverage and automation.

2. Domain scores

Domain	Weight	Score	Profile
Strategy & Accountability	12%	73.3	[###############.....]
AI Inventory & Visibility	14%	73.3	[###############.....]
Risk Management & Lifecycle	14%	66.7	[#############.......]
Data & Privacy	12%	73.3	[###############.....]
Security & Resilience	14%	73.3	[###############.....]
Fairness, Safety & Transparency	12%	60.0	[############........]
Human Oversight & Operations	12%	66.7	[#############.......]
Assurance, Evidence & Improvement	10%	66.7	[#############.......]

Scoring: domain score = sum of answers ÷ maximum possible × 100; overall = Σ(domain score × weight). Source: VERITRAIL self-assessment template VERITRAIL-SA-MATURITY v1.0.0.

3. Top strengths

- **AI Inventory & Visibility** — Does your organization maintain a complete inventory of AI systems, models, agents, and vendor AI products? (answer 4/5; question INV-Q1; controls EI-01, EI-08, EI-09) — *User-asserted*
- **AI Inventory & Visibility** — Can you identify the owner, purpose, users, data sources, and dependencies for each material AI system? (answer 4/5; question INV-Q3; controls EI-03, EI-04, EI-06, EI-10) — *User-asserted*
- **Risk Management & Lifecycle** — Are model, prompt, data, vendor, and agent changes subject to change control and reassessment? (answer 4/5; question RSK-Q2; controls GL-04, EI-05) — *User-asserted*
- **Security & Resilience** — Are AI systems included in threat modeling, security review, and vulnerability-management processes? (answer 4/5; question SEC-Q1; controls IS-01, IS-10) — *User-asserted*
- **Security & Resilience** — Can you disable or roll back an AI system, model, agent, or tool quickly after a security or safety incident? (answer 4/5; question SEC-Q3; controls IS-15) — *User-asserted*

4. Top gaps

#	Domain	Question	Answer	Recommended action	VERITRAIL controls
1	Fairness, Safety & Transparency	FST-Q3: Are explanations, disclosures, and appeal mechanisms available for affected individuals where appropriate?	2/5	Provide explanation and appeal routes for individuals affected by AI-influenced decisions.	IS-08, IS-09, AO-11
2	AI Inventory & Visibility	INV-Q2: Are AI systems classified by business criticality, data sensitivity, decision impact, autonomy, and regulatory relevance?	3/5	Apply VERITRAIL risk-tier criteria to every inventory record and approve tier assignments.	EI-02
3	Risk Management & Lifecycle	RSK-Q1: Do AI use cases undergo risk assessment before production deployment?	3/5	Make a tier-proportionate risk and impact assessment a mandatory gate before any production deployment.	GL-01, GL-02, GL-03
4	Risk Management & Lifecycle	RSK-Q3: Is there a defined process for retiring, restricting, or remediating AI systems that no longer meet requirements?	3/5	Define restrict/remediate/retire procedures and an exception register with expiry dates.	GL-09, GL-10
5	Security & Resilience	SEC-Q2: Are LLM applications and agents tested for prompt injection, jailbreak, data leakage, and unsafe tool use?	3/5	Run adversarial testing (prompt injection, jailbreak, leakage, unsafe tool use) before release and after material change.	IS-14, IS-11, IS-12

5. Critical risk flags

- No critical risk flags were triggered by your answers.

6. 30/60/90-day action plan

First 30 days — stabilise

- Provide explanation and appeal routes for individuals affected by AI-influenced decisions. (Fairness, Safety & Transparency; FST-Q3; controls IS-08, IS-09, AO-11)

Days 31–60 — standardise

- Apply VERITRAIL risk-tier criteria to every inventory record and approve tier assignments. (AI Inventory & Visibility; INV-Q2; controls EI-02)
- Make a tier-proportionate risk and impact assessment a mandatory gate before any production deployment. (Risk Management & Lifecycle; RSK-Q1; controls GL-01, GL-02, GL-03)
- Define restrict/remediate/retire procedures and an exception register with expiry dates. (Risk Management & Lifecycle; RSK-Q3; controls GL-09, GL-10)
- Run adversarial testing (prompt injection, jailbreak, leakage, unsafe tool use) before release and after material change. (Security & Resilience; SEC-Q2; controls IS-14, IS-11, IS-12)
- Charter a cross-functional AI governance forum with documented authority to approve, restrict or stop use cases. (Strategy & Accountability; STR-Q2; controls AO-02)

Days 61–90 — scale and automate

- Stand up an AI system of record and run inventory workshops plus shadow-AI discovery to reach full coverage. (AI Inventory & Visibility; INV-Q1; controls EI-01, EI-08, EI-09)
- Complete owner, purpose, users, data-source and dependency fields for all material AI systems. (AI Inventory & Visibility; INV-Q3; controls EI-03, EI-04, EI-06, EI-10)
- Add AI-specific change triggers (model, prompt, data, vendor, tool, agent) to change management with reassessment rules. (Risk Management & Lifecycle; RSK-Q2; controls GL-04, EI-05)
- Extend threat modelling, security review and vulnerability management to all AI systems and model supply chains. (Security & Resilience; SEC-Q1; controls IS-01, IS-10)
- Implement and test a kill switch and rollback runbook for every production AI system and agent. (Security & Resilience; SEC-Q3; controls IS-15)

7. Recommended VERITRAIL controls

Control	Pillar	Priority	NIST AI RMF	ISO/IEC 42001	EU AI Act
IS-08 Transparency and AI disclosures	IS	high	MEASURE 2.8, MEASURE 2.9	A.8.2, A.8.5	Art. 13, Art. 50
IS-09 Human oversight design	IS	critical	GOVERN 3.2, MAP 3.5	A.9.2, A.6.2.6	Art. 14, Art. 26
AO-11 Stakeholder engagement and feedback	AO	medium	GOVERN 5.1, GOVERN 5.2	4.2, A.8.3, A.8.5	Art. 27
EI-02 AI risk classification and tiering	EI	critical	MAP 1.1, MAP 1.5, GOVERN 1.3	6.1.2, A.5.2	Art. 6
GL-01 Intake triage workflow	GL	high	MAP 1.1, MAP 1.6	8.1, A.6.1.3	Art. 9
GL-02 Pre-deployment risk and impact assessment	GL	critical	MAP 1.1, MAP 3.1, MAP 5.1, MEASURE 1.1	6.1.4, 8.4, A.5.2, A.5.3, A.5.4	Art. 9, Art. 27
GL-03 Risk-tiered approval gates	GL	critical	MANAGE 1.1, GOVERN 1.4	8.1, A.6.2.5	Art. 9, Art. 43
GL-09 Retirement and decommissioning	GL	medium	GOVERN 1.7, MANAGE 2.4	A.6.2.6	—
GL-10 Exceptions and risk acceptance	GL	high	MANAGE 1.3, MANAGE 1.4	6.1.3	Art. 9
IS-14 Prompt-injection and data-leakage testing	IS	critical	MEASURE 2.7	A.6.2.4	Art. 15

Framework mappings are indicative VERITRAIL interpretations (Control Library v1.0.0).

8. Framework readiness indicators (indicative — not a compliance determination)

NIST AI RMF

Area	Indicator	Band	Based on questions
GOVERN	72.0	Partial readiness	STR-Q1, STR-Q2, STR-Q3, HUM-Q3, ASR-Q3
MAP	72.0	Partial readiness	INV-Q1, INV-Q2, INV-Q3, RSK-Q1, DAT-Q1
MEASURE	64.0	Partial readiness	SEC-Q2, FST-Q1, HUM-Q2, ASR-Q1, DAT-Q2
MANAGE	68.0	Partial readiness	RSK-Q2, RSK-Q3, SEC-Q3, HUM-Q1, ASR-Q2

ISO/IEC 42001

Area	Indicator	Band	Based on questions
Context & leadership (Cl. 4–5, A.2–A.3)	73.3	Partial readiness	STR-Q1, STR-Q2, STR-Q3
Planning & impact assessment (Cl. 6, A.5)	60.0	Partial readiness	INV-Q2, RSK-Q1, FST-Q1
Support & documented information (Cl. 7, A.4)	66.7	Partial readiness	HUM-Q3, INV-Q1, ASR-Q2
Operation & lifecycle (Cl. 8, A.6–A.7)	75.0	Substantial readiness	RSK-Q2, DAT-Q1, DAT-Q2, SEC-Q1
Performance evaluation (Cl. 9)	70.0	Partial readiness	HUM-Q2, ASR-Q1
Improvement (Cl. 10)	70.0	Partial readiness	ASR-Q3, RSK-Q3

EU AI Act

Area	Indicator	Band	Based on questions
AI literacy (Art. 4)	60.0	Partial readiness	HUM-Q3
Risk management (Art. 9)	66.7	Partial readiness	RSK-Q1, RSK-Q2, INV-Q2
Data governance (Art. 10)	66.7	Partial readiness	DAT-Q1, DAT-Q2, FST-Q1
Technical documentation & record-keeping (Art. 11–12)	70.0	Partial readiness	INV-Q3, ASR-Q2

Area	Indicator	Band	Based on questions
Transparency (Art. 13, Art. 50)	60.0	Partial readiness	FST-Q2, FST-Q3
Human oversight (Art. 14)	70.0	Partial readiness	HUM-Q1, SEC-Q3
Accuracy, robustness & cybersecurity (Art. 15)	70.0	Partial readiness	SEC-Q1, SEC-Q2
Post-market monitoring & incidents (Art. 72–73)	70.0	Partial readiness	HUM-Q2, ASR-Q1

These indicators summarise self-reported practices that relate to each framework area. They do not indicate conformity with ISO/IEC 42001, compliance with the EU AI Act, or alignment with NIST AI RMF, and EU AI Act applicability depends on your role (provider/deployer) and system classification.

9. Recommended VERITRAIL modules

- **VERITRAIL Assess** — Establish an evidence-based baseline of maturity and use-case risk.
- **VERITRAIL Shield** — Enforce runtime guardrails, approvals and containment for LLM apps and agents.
- **VERITRAIL Agent** — Accelerate assessments, gap analysis and reporting with a citation-backed governance copilot.

10. Next step: VERITRAIL Governance Baseline

A fixed-scope 4–6 week engagement — inventory up to 25 AI systems, validate this maturity baseline with evidence, deep-dive five priority systems, review two agents, and deliver a gap register, remediation roadmap and executive readiness report.

Book an VERITRAIL Governance Baseline: /contact/book-governance-baseline/

Appendix A — Your answers

Question	Answer
STR-Q1: Does your organization have a documented AI governance policy and accountable ownership model?	4 — Consistently implemented
STR-Q2: Is there a cross-functional AI governance forum with authority to approve, restrict, or stop AI use cases?	3 — Defined for some systems
STR-Q3: Are AI roles, responsibilities, and escalation paths defined for business, technology, risk, legal, and security teams?	4 — Consistently implemented
INV-Q1: Does your organization maintain a complete inventory of AI systems, models, agents, and vendor AI products?	4 — Consistently implemented
INV-Q2: Are AI systems classified by business criticality, data sensitivity, decision impact, autonomy, and regulatory relevance?	3 — Defined for some systems
INV-Q3: Can you identify the owner, purpose, users, data sources, and dependencies for each material AI system?	4 — Consistently implemented
RSK-Q1: Do AI use cases undergo risk assessment before production deployment?	3 — Defined for some systems
RSK-Q2: Are model, prompt, data, vendor, and agent changes subject to change control and reassessment?	4 — Consistently implemented
RSK-Q3: Is there a defined process for retiring, restricting, or remediating AI systems that no longer meet requirements?	3 — Defined for some systems
DAT-Q1: Are data sources, data classifications, and data flows documented for AI systems?	4 — Consistently implemented
DAT-Q2: Are privacy, consent, retention, cross-border transfer, and data-minimization requirements assessed?	3 — Defined for some systems
DAT-Q3: Are sensitive data fields redacted, masked, or excluded from prompts, logs, and external model calls?	4 — Consistently implemented
SEC-Q1: Are AI systems included in threat modeling, security review, and vulnerability-management processes?	4 — Consistently implemented
SEC-Q2: Are LLM applications and agents tested for prompt injection, jailbreak, data leakage, and unsafe tool use?	3 — Defined for some systems

Question	Answer
SEC-Q3: Can you disable or roll back an AI system, model, agent, or tool quickly after a security or safety incident?	4 — Consistently implemented
FST-Q1: Are AI systems assessed for bias, discriminatory outcomes, safety risks, and unintended harm?	3 — Defined for some systems
FST-Q2: Are users informed when they are interacting with AI or when AI materially influences a decision?	4 — Consistently implemented
FST-Q3: Are explanations, disclosures, and appeal mechanisms available for affected individuals where appropriate?	2 — Initial / ad hoc
HUM-Q1: Are human-review, override, escalation, and appeal mechanisms defined for high-impact AI decisions?	3 — Defined for some systems
HUM-Q2: Are AI systems monitored for performance, drift, misuse, incidents, and unexpected behavior?	4 — Consistently implemented
HUM-Q3: Are operators and affected teams trained on AI limitations, escalation paths, and responsible use?	3 — Defined for some systems
ASR-Q1: Are AI controls tested periodically, with evidence retained for audit and review?	3 — Defined for some systems
ASR-Q2: Can your organization produce an audit-ready evidence pack for a material AI system on request?	3 — Defined for some systems
ASR-Q3: Are AI governance metrics reviewed by leadership and used to drive corrective action?	4 — Consistently implemented

Appendix B — Sources

- VERITRAIL Control IS-08: Transparency and AI disclosures (Control Library v1.0.0)
- VERITRAIL Control IS-09: Human oversight design (Control Library v1.0.0)
- VERITRAIL Control AO-11: Stakeholder engagement and feedback (Control Library v1.0.0)
- VERITRAIL Control EI-02: AI risk classification and tiering (Control Library v1.0.0)
- VERITRAIL Control GL-01: Intake triage workflow (Control Library v1.0.0)
- VERITRAIL Control GL-02: Pre-deployment risk and impact assessment (Control Library v1.0.0)
- VERITRAIL Control GL-03: Risk-tiered approval gates (Control Library v1.0.0)
- VERITRAIL Control GL-09: Retirement and decommissioning (Control Library v1.0.0)
- VERITRAIL Control GL-10: Exceptions and risk acceptance (Control Library v1.0.0)
- VERITRAIL Control IS-14: Prompt-injection and data-leakage testing (Control Library v1.0.0)
- VERITRAIL Self-Assessment template VERITRAIL-SA-MATURITY v1.0.0

VERITRAIL supports governance readiness, control implementation and evidence collection. It does not certify ISO/IEC 42001 conformity, guarantee EU AI Act compliance, or replace legal advice. Framework mappings are indicative.